PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Modèle Zero Trust (ZT)

03-200 ANSSI - Modèle Zero Trust — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le modèle Zero Trust vise à réduire la confiance implicite accordée à un sujet souhaitant accéder au système d'information.
2. Le contrôle d'accès logique repose sur une évaluation dynamique et régulière du sujet, du contexte d'accès et de la criticité de la ressource.
3. L'ABAC permet une évaluation dynamique et continue des demandes d'accès selon les attributs du sujet, de la ressource et de l'environnement.

Nature du modèle Zero Trust

Notion	À retenir
Modèle de sécurité	Ce n'est **pas une technologie** ou solution commerciale, mais un modèle pour renforcer la **sécurité d'accès** via la **défense en profondeur** (authentification, moindre privilège, micro-segmentation).
Contrôle d'accès logique	Repose sur l'évaluation dynamique et régulière du **sujet**, du **contexte d'accès** (état de sécurité du poste) et de la **criticité de la ressource** (disponibilité, intégrité, confidentialité).
Risque d'adoption	L'adoption doit être **maîtrisée et progressive** pour éviter d'**affaiblir le SI** et de créer un **faux sentiment de sécurité**.

Démarche de transformation vers le Zero Trust

Notion	À retenir
Défense en profondeur	Approche **complémentaire** à la défense périmétrique, intégrée dans une démarche de maîtrise des risques.
Cas d'usage et politique	Définir les cas d'usage (qui, contexte, ressources) et une politique sur la base d'**attributs maîtrisés**.
Cartographie et tests	Cartographier (applicatifs, données, utilisateurs, équipements, flux) et réaliser des **tests de sécurité/bon fonctionnement** avant mise en production.
Centralisation du contrôle	Porter une attention particulière à la centralisation des fonctions de contrôle d'accès logique et à l'impact d'une atteinte en **disponibilité** ou en **intégrité**.

Principes techniques du Zero Trust

Notion	À retenir
Modèle ABAC	Évaluation **dynamique et continue** selon les attributs du **sujet** (fonction), de la **ressource** (confidentialité) et **environnementaux** (conformité, heure, lieu).
Gestion et supervision	Automatisation du cycle de vie des **comptes/authentifiants**, de la **conformité (correctifs)** et de la **supervision** (analyse des événements avec **faible taux de faux positifs/négatifs**).
Authentification et durcissement	Utilisation de l'**authentification multifacteur forte** et d'**équipements durcis et maîtrisés** pour les données critiques (sur les équipements personnels, la **visibilité** sur leur état de sécurité est jugée **insuffisante**).

Pièges et confusions

⚠ Croire que le Zero Trust remplace la défense périmétrique au lieu de la compléter.
⚠ Négliger les mesures périmétriques existantes lors d'un projet Zero Trust.
⚠ Baser la politique de contrôle d'accès sur des attributs dont l'entité ne connaît pas précisément la qualité ou la couverture.
⚠ Oublier de tester la sécurité et le bon fonctionnement avant la mise en production.

Sigles et définitions

Zero Trust (ZT)	Modèle de sécurité dont l'objectif principal est de réduire la confiance implicite accordée à un sujet souhaitant accéder au système d'information.
ABAC	Modèle de contrôle des autorisations permettant l'évaluation dynamique et continue des demandes d'accès selon les attributs du sujet, de la ressource et de l'environnement.
Micro-segmentation	Principe de défense en profondeur réutilisé par le modèle Zero Trust pour isoler finement les ressources d'un système d'information.
Contrôle d'accès logique	Repose sur une évaluation dynamique et régulière du sujet, du contexte d'accès, et de la criticité de la ressource accédée en disponibilité, intégrité et confidentialité.

Auto-test

1. Le Zero Trust est-il une solution commerciale ?
2. Quels sont les trois éléments de l'évaluation du contrôle d'accès logique ?
3. Que doit-on faire avant la mise en production ?
4. Pourquoi écarter les équipements personnels pour les données critiques ?
5. Sur quoi doit reposer la politique de contrôle d'accès pour être fiable ?

Réponses : **1.** Non, c'est un modèle. · **2.** Le sujet, le contexte d'accès et la criticité de la ressource. · **3.** Cartographier et réaliser des tests de sécurité/bon fonctionnement. · **4.** La visibilité sur leur état de sécurité et la confiance dans ce qu'ils remontent sont insuffisantes. · **5.** Sur des attributs maîtrisés.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.